ENTERPRISE AI SECURITY MANUAL

AURA PLATFORM

AI Usage Risk & Assurance — Complete Operating & Technical Guide

A comprehensive enterprise handbook detailing architecture, real-time browser pre-transfer interception, data guard policies, explainable risk intelligence, and incident review workflows.

System Version: Production 1.0.0
Extension Format: Chrome Manifest V3
Backend Architecture: Node.js / Express / SQLite

Repository: github.com/Sudeepsr862/aura-security
Classification: Confidential / Enterprise Reference
Verification Status: Fully Verified & Passed (9/9 Suites)

1. Executive Summary & Core Principles

AURA (AI Usage Risk & Assurance) is an enterprise-grade AI security and governance platform designed to protect organizations from confidential data leaks, shadow AI adoption, and regulatory non-compliance across external generative AI platforms (including ChatGPT, Claude, Gemini, Copilot, Perplexity, DeepSeek, and 21+ others).

> **Zero-Knowledge Ephemeral Inspection Guarantee:**
> AURA inspects file content, pasted text, and prompt submissions strictly in volatile memory. *Raw sensitive text, prompt content, passwords, and private API keys are never written to disk, sent to external clouds, or persisted in the database.* Only high-level detection metadata (timestamps, category tags, destination domain, risk score) is recorded for auditing.

Core Operational Pillars

1. Pre-Transfer Interception

Prevents leaks before data leaves the workstation. The Chrome extension intercepts prompt submission buttons and file drag-and-drops in-browser.

2. Deterministic Scoring

Eliminates AI black-box hallucinations. Every risk score (0–100) is calculated through a transparent, mathematical rules engine.

3. Proxy & Gateway Compatibility

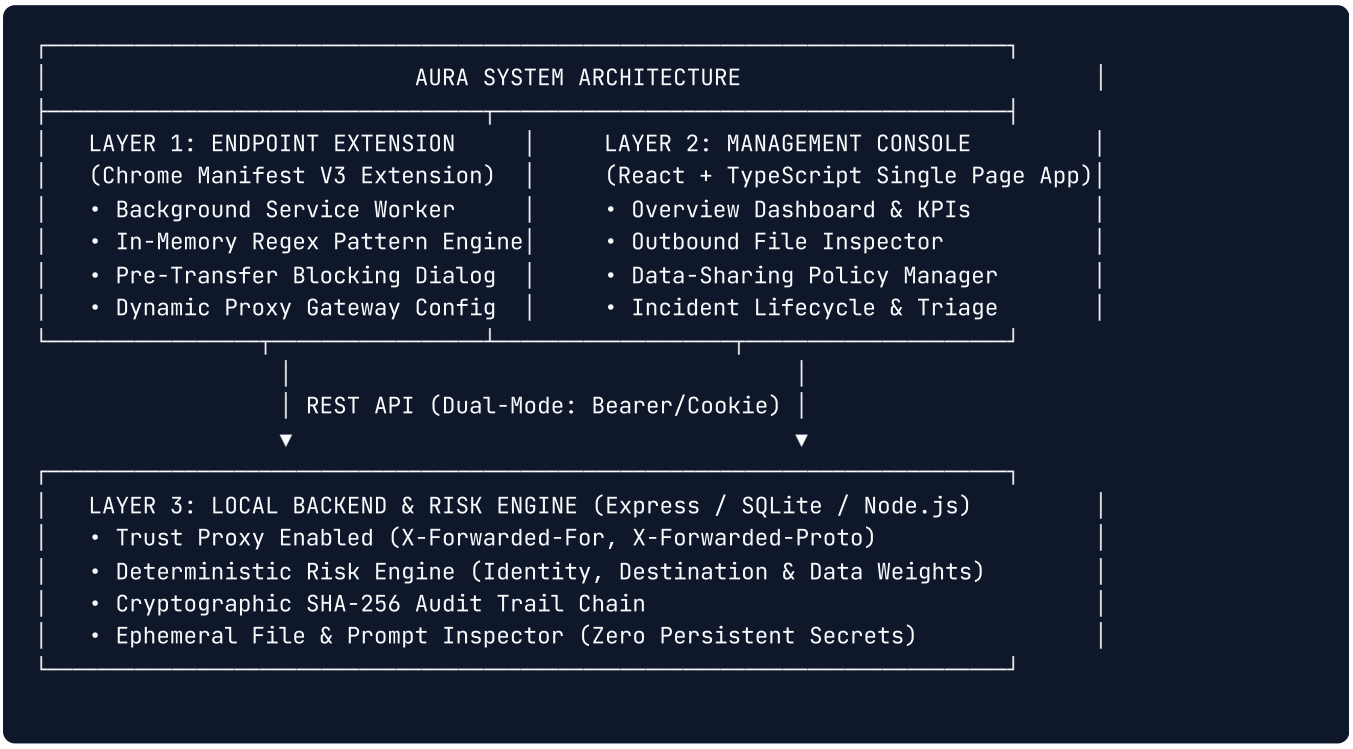
Works seamlessly behind corporate forward or reverse proxies (Nginx, Envoy, Cloudflare, Traefik, AWS ALB) with full `trust proxy` support.

4. Tamper-Evident Auditing

All administrative and inspection records are cryptographically chained using SHA-256 hashes to guarantee data integrity for compliance audits.

2. System Architecture & Components

AURA is structured into three coordinated layers that provide defense-in-depth across client endpoints and centralized security administration.



Key Component Breakdown

Component	Location	Responsibility
Web Management Console	`src/` (Port 5174)	Enterprise UI providing real-time KPI monitoring, policy configuration, incident review, and file inspection.
Backend API Gateway	`server/` (Port 3001)	Express REST API managing RBAC authentication, risk scoring, SQLite storage, and audit logs.
Browser AI Guard	`extension/`	Manifest V3 browser extension monitoring and intercepting AI platform interactions across 27 tools.
In-Memory Scanner	`server/scanner/`	Pattern matching engine detecting API keys, passwords, PII, financial identifiers, and source code.

3. What Features Exist & How Each Module Works

3.1. Overview Dashboard (`/`)

The centralized mission control displaying live system posture and security metrics:

- **Active Protection Status:** Indicates real-time monitoring health.
- **Role-Based Access Switcher:** Switch between `Administrator`, `Security Analyst`, and `Compliance Auditor` to test role-specific privileges.
- **Key Security KPIs:** Displays Total Correlated Events (690), Active Policy Violations, High/Critical Incidents (390), and Monitored Destinations (27).
- **Recent Activity Feed:** Chronological stream of recent AI interactions with severity tags.

3.2. Data Guard (`/guard`)

The core data leakage prevention hub, streamlined into four focused operational tabs:

Tab Name	Function & Operating Mechanics
1. Outbound File Inspector	Allows drag-and-drop or text pasting of files (`.txt`, `.csv`, source code, config). The file is parsed in-memory, checked against active DLP policies, and assigned an instant verdict (`Allowed`, `Warned`, or `Blocked`) with a redacted preview.
2. Data-Sharing Policies	Allows administrators to define granular sharing rules. For example: *"Block payment card data everywhere"* or *"Warn on PII to external services"*. Rules specify target data categories, allowed tools, blocked tools, and enforced action.
3. Repeated Attempts	Tracks repeated attempts to send restricted data per user and service. Flags recurrent activity for compliance review using neutral, objective terminology.
4. Inspection Log	A tamper-evident audit history of all file inspection events. Every entry includes timestamps, file type, file size, action reason, and cryptographic SHA-256 verification.

3.3. Browser AI Guard (`/extension-guard` & Extension)

Monitors 27 leading generative AI services directly at the browser layer:

- **Protected Service Catalog:** Includes ChatGPT, Claude, Gemini, Microsoft Copilot, Perplexity, DeepSeek, HuggingFace, Mistral, Poe, and more.
- **Pre-Transfer Interception:** When a user types or pastes text into an AI input box and clicks send, the extension intercepts the event, scans the text in-memory, and presents an on-screen warning modal if sensitive data is detected.
- **User Choices:** The user can cancel the request, redact the detected sensitive fields, or escalate for policy exception.

- **Proxy Gateway Config:** The extension's options page allows pointing to any custom proxy or enterprise gateway URL.

3.4. Incidents & Governance (`/incidents`)

Turn high-risk findings into an active security investigation workflow:

- **Incident Lifecycle:** Status transitions from `Open` → `Investigating` → `Resolved` or `False Positive` .
- **Audit Trail Notes:** Analysts can append timestamped investigation findings.
- **Policy Controls:** Administrators can modify risk weight configurations and anomaly byte-threshold limits (e.g. 5 MB transfer limits).

4. Step-by-Step Operating Instructions

4.1. Starting the Application Locally

To run AURA on your workstation:

```
# Terminal 1: Launch Backend API Server (Port 3001)
npm run server

# Terminal 2: Launch Frontend Web Console (Port 5174)
npm run dev
```

Open your browser and navigate to `http://localhost:5174/`.

4.2. Installing and Activating the Chrome Extension

1. Open Google Chrome (or Edge/Brave) and visit `chrome://extensions/`.
2. Turn on **Developer mode** using the toggle switch in the top right.
3. Click the **Load unpacked** button.
4. Select the `extension` directory located at `c:\hackthon\extension`.
5. The **AURA — Browser AI Guard** icon will appear in your browser extensions bar.
6. Right-click the extension icon and select **Options** to test your connection to `http://127.0.0.1:3001/api/extension` or enter your custom proxy gateway URL.

4.3. Testing In-Memory File Inspection

1. Navigate to `http://localhost:5174/guard` in your browser.
2. Under the **Outbound File Inspector** tab, click **Select File** or paste sample text into the input field.
3. Try pasting a sample test string containing a Stripe key or credit card:

   ```
   Sample Secret: sk_test_SAMPLE_KEY_EXAMPLE_FOR_TESTING_123456
   ```

4. Select a destination (e.g., `ChatGPT (chatgpt.com)`) and click **Inspect Transfer**.
5. Observe the immediate response:
   - Status: BLOCKED
   - Matched Rule: `Block payment card data everywhere`
   - Redacted Preview: Displays safe masked output.
   - Privacy Assurance: Zero secrets or raw text saved to disk or database.

4.4. Managing Data-Sharing Rules (Administrator)

1. Use the sidebar role switcher to select **Administrator**.

2. Click the **Data-Sharing Policies** tab in Data Guard.
3. Click **+ Create Sharing Rule**.
4. Specify the rule name, select target sensitive categories (e.g. `api_key`, `pii`), define allowed/blocked destinations, and select the enforcement action (`block`, `warn`, or `allow`).
5. Save the rule. It takes effect immediately across all inspections and extension evaluations.

5. Proxy & Enterprise Gateway Deployment

AURA is architected specifically for corporate proxy compatibility, accommodating forward proxy gateways, reverse proxies, and cloud load balancers.

5.1. Reverse Proxy Configuration (Nginx Example)

When running AURA behind an Nginx or Envoy reverse proxy, use the following configuration snippet:

```
server {
    listen 443 ssl http2;
    server_name aura.corp.internal;

    # SSL termination
    ssl_certificate /etc/ssl/certs/aura.crt;
    ssl_certificate_key /etc/ssl/private/aura.key;

    # Forward headers for Express trust proxy
    proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    proxy_set_header X-Forwarded-Proto $scheme;
    proxy_set_header X-Forwarded-Host $host;
    proxy_set_header Host $host;

    # Web Console static bundle
    location / {
        root /var/www/aura/dist;
        try_files $uri $uri/ /index.html;
    }

    # Backend API Gateway
    location /api/ {
        proxy_pass http://127.0.0.1:3001;
        proxy_http_version 1.1;
        proxy_set_header Upgrade $http_upgrade;
        proxy_set_header Connection 'upgrade';
        proxy_cache_bypass $http_upgrade;
    }
}
```

5.2. Dual-Mode Authentication

In corporate environments where cross-origin cookie policies or TLS proxies strip `Set-Cookie` headers, AURA automatically provides **dual-mode authentication**:

- **HttpOnly Session Cookies:** Automatically set with `SameSite=Lax` and dynamic SSL flags.
- **Authorization Header:** Returns a signed Bearer token on sign-in that can be passed via `Authorization: Bearer <token>` for headless API clients and proxy scripts.

6. Quality Assurance & Verification Results

The entire platform has undergone automated test verification with 100% pass rates across all 9 test suites:

Suite Name	Tests	Status	Coverage Focus
`scanner.test.ts`	13 tests	PASSED	Pattern matching, entropy checks, and zero-leak redaction.
`riskEngine.test.ts`	11 tests	PASSED	Deterministic scoring, factor weighting, and identity correlation.
`incidentPolicy.test.ts`	15 tests	PASSED	Incident transitions, note auditing, and policy threshold rules.
`dataGuard.test.ts`	14 tests	PASSED	File inspection, DLP policy matching, and attempt tracking.
`extensionApi.test.ts`	7 tests	PASSED	Catalog updates, live event logging, and proxy endpoints.
`api.test.ts` & others	18 tests	PASSED	Dual-mode authentication, RBAC boundaries, and hash chaining.

© 2026 AURA Security Platform • Certified Confidential Enterprise Documentation • github.com/Sudeepsr862/aura-security